Іван Гокін

Розвідка кіберзагроз: шо воно таке?

Що таке CTI, хто цим займається в Україні і як працює цикл розвідки



ДАВАЙТЕ ЗНАЙОМИТИСЬ

Іван Гокін

Врядування, ризики й відповідність у кібербезпеці

ЧОМУ ЦЯ ТЕМА

Війна рф проти України. Керівництво має отримувати актуальну й дієву інформацію про кіберзагрози — мені стало цікаво розібратись, як це працює.

СТАТУС

Роль	**IT-аудитор**
Сертифікація	**CISA**
Досвід	**5+ років**
Сфера	**Консалтинг та аудит**
Зв’язок	LinkedIn · GitHub

ПЛАН

Що ми обговоримо

1

Що це і навіщо

Визначення, призначення, цінність даних

2

Професія

Навички, перспективи, інструменти

3

Процес

Цикл розвідки від планування до обміну

4

Кого почитати

Стандарти, курси, практика — у додатках

I

Що це і навіщо

Визначення, для чого розвідку використовують і яка інформація справді цінна

ВИЗНАЧЕННЯ

Питання, на які відповідає розвідка

Хто може нас атакувати і чим?

Цей файл справді шкідливий?

Як нам провести полювання на загрозу APT28?

Чи достатньо наших інструментів для захисту від актуальних загроз?

«

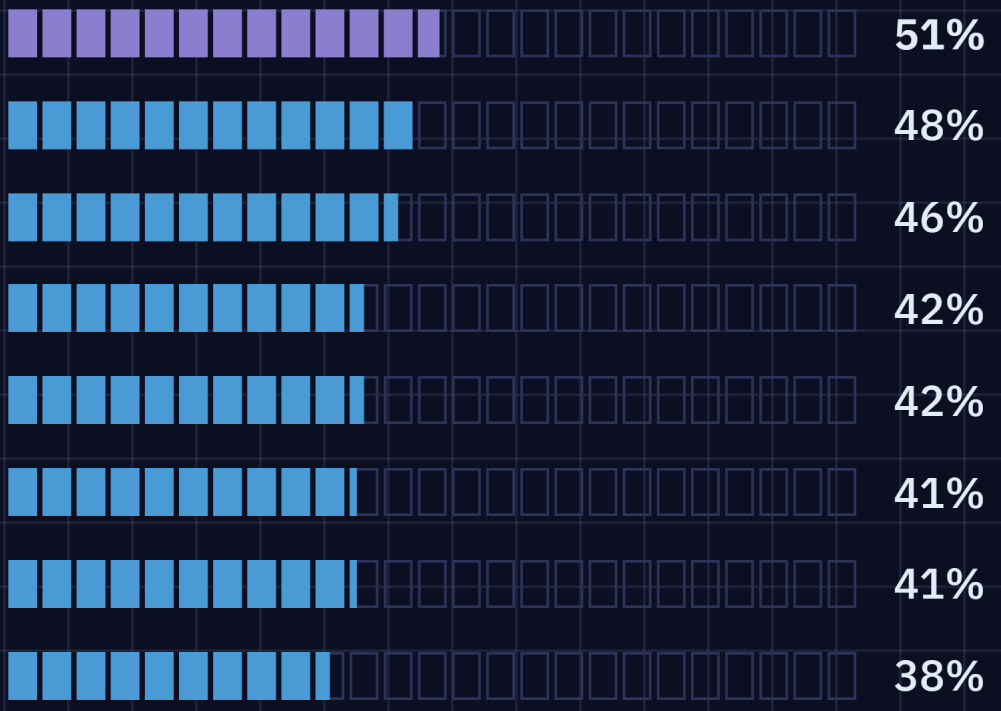
Розвідка загроз — процес збору, обробки, аналізу, тлумачення та збагачення інформації про загрози для надання необхідного контексту для прийняття рішень.

NIST SP 800-150

Guide to Cyber Threat Information Sharing · переклад автора

ПРИЗНАЧЕННЯ

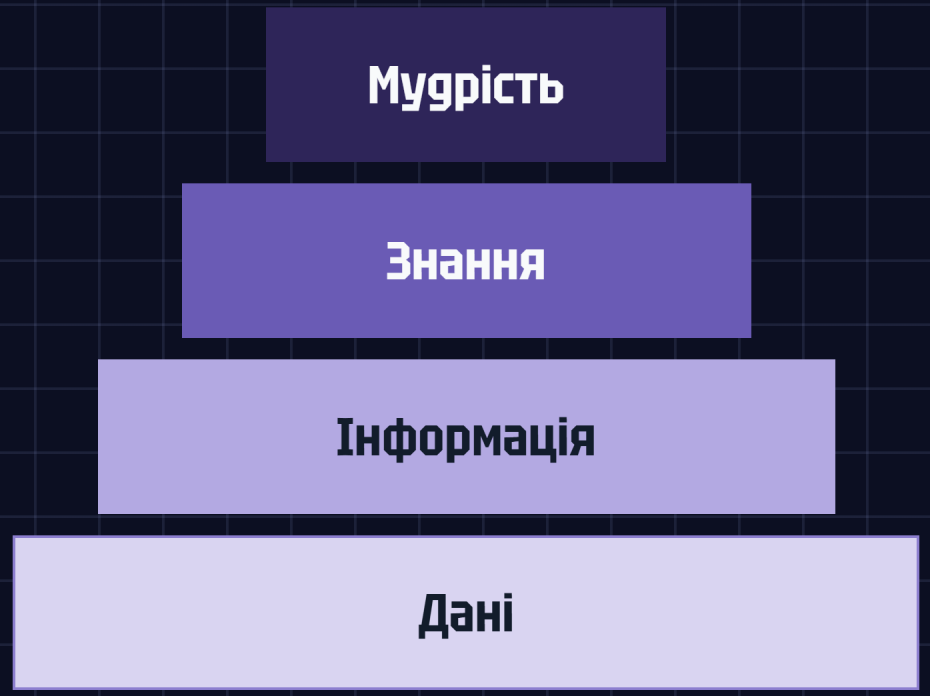
Для чого організації використовують розвідку



Джерело: Trellix, The Mind of the CISO

ОБРОБКА ІНФОРМАЦІЇ

Від даних до мудрості



Заходи, виконані на основі порад

Дієві поради на основі підтверджених атак

Описи кібератак, кампаній, ландшафтів загроз

Індикатори компрометації

Піраміда «інформації»: кожен рівень вище — менше обсягу і більше користі

ГОЛОВНА ДУМКА

Споживач розвідки не має ні часу, ні бажання читати сирі дані

Задача аналітика — відфільтрувати все зайве й дати рівно те, що споживач з користю і мінімальними зусиллями застосує у своїй роботі.

ЩО КАЖУТЬ КЕРІВНИКИ

Розвідка кіберзагроз цінна, але не впливає на рішення

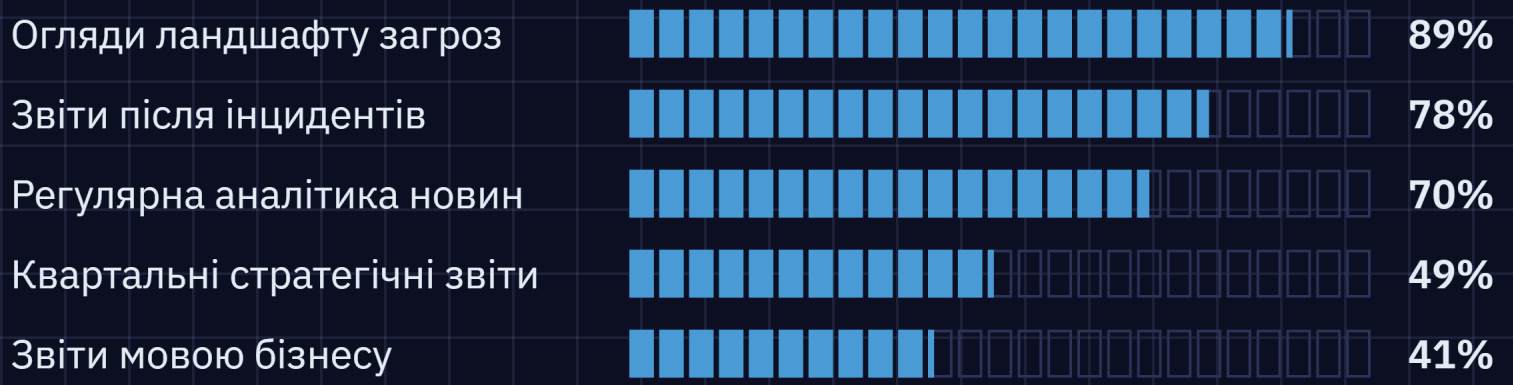
91%

CISO вважають розвідку цінною

26%

кажуть, що вона суттєво впливає на їхні рішення

ЯКІ ЗВІТИ CISO ВВАЖАЮТЬ КОРИСНИМИ



Проблема не в точності, а в дієвості: розвідка має підказувати можливі рішення керівнику.

Опитування 67 CISO і CSO · SANS CTI Survey 2026

РІВНІ АБСТРАКЦІЇ

Тактична, оперативна і стратегічна розвідка

	Тактична	Оперативна	Стратегічна
Питання	Що саме сталося?	Як і де? (TTP)	Хто і чому? (атрибуція, мотив, намір)
Про що	Низькорівневі технічні деталі окремих атак	Кампанії атак і зловмисники, середній рівень деталей	Тенденції атак і ландшафт загроз, найменш технічний рівень
Горизонт	Короткостроковий	Поточні кампанії	Довгостроковий
Кому	Системам захисту: IOC з контекстом	Командам реагування й полювання	Керівництву: регулярні звіти

ПІРАМІДА БОЛЮ

Що цікаво споживачам інформації

Індикатор компрометації — артефакт у мережі чи ОС, який із високою достовірністю вказує на вторгнення.

Праворуч — наскільки зловмиснику боляче змінити індикатор.

Найцінніше — **TTP**, які ви, ймовірно, знаєте з MITRE ATT&CK.



Джерело: Pyramid of Pain, Девід Б’янко

II

Професія CTI-аналітика

Що треба вміти, де працюють, які перспективи і з якими інструментами

НАВИЧКИ · ECSF, ENISA

Що треба вміти CTI-аналітику

ВМІННЯ

- Командна робота
- Збір, аналіз і співвіднесення інформації з різних джерел
- Ідентифікація суб’єктів загроз, TTP і кампаній
- Автоматизація управління інформацією про загрози
- Технічний аналіз і звітування
- Виявлення «некібер» подій, що впливають на кібердіяльність
- Моделювання загроз
- Комунікація, координація і звітування перед зацікавленими сторонами

ЗНАННЯ

- Безпека операційних систем і мереж
- Системи кібербезпеки
- Програмування
- Відповідальне розкриття інформації
- Міжгалузеві знання, пов’язані з кібербезпекою
- Суб’єкти кіберзагроз
- Сучасні й постійні загрози (APT)
- Тактики, техніки та процедури (TTP)

СЕРТИФІКАЦІЇ

З чого почати і куди рости

СТАРТ

arcX CTI 101

Безкоштовна базова сертифікація

ЗРІЛІСТЬ

CREST

Достатньо зрілі сертифікації з розвідки загроз

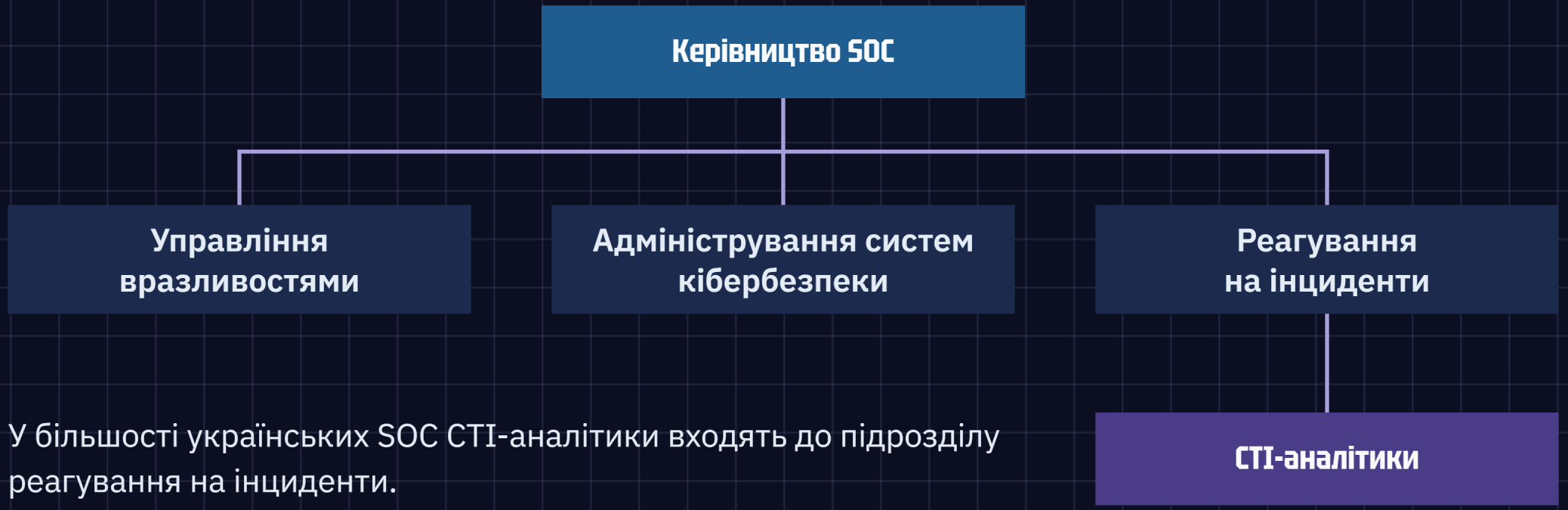
УКРАЇНА

Профстандарт «Аналітик загроз безпеки»

Першоджерело — роль Threat Analysis з NIST NICE

СТРУКТУРА SOC

Де організаційно знаходяться CTI-аналітики



У більшості українських SOC CTI-аналітики входять до підрозділу реагування на інциденти.

Джерело: MITRE, 11 Strategies of a World-Class Cybersecurity Operations Center

ПЕРСПЕКТИВНІСТЬ

Професія CTI-аналітика на ринку України

- Основні роботодавці зараз — державні установи, MSP і компанії з розвідки кіберзагроз.
- Адаптація NIS2 та DORA підвищить попит, зокрема для пентестів на основі розвідки (TLPT).
- Держспецзв'язку адаптувала професійний стандарт: підготовка за ним за 3–4 роки має заповнити посади в держорганах.

> **Важливо:** передумови для росту попиту є, але бізнесу користь розвідки поки неочевидна.

ХТО НАЙМАЄ

Recorded Future · INTEL471 · SOC PRIME · osavul

Ринок у світі: The Business Research Company, Cyber Threat Intelligence Global Market Report 2025

ІНСТРУМЕНТИ

Платформи розвідки кіберзагроз

ОСНОВНІ ФУНКЦІЇ

- Збір та аналіз даних
- Аналіз і кореляція загроз
- Збагачення розслідувань інцидентів
- Збагачення систем кібербезпеки

OPEN SOURCE

MISP

- Проста в базовому варіанті
- Модулі обираєте самі
- Використовується в Україні
- Підтримується Єврокомісією

ГОТОВА З КОРОБКИ

OpenCTI

- Зріла система з багатьма інтеграціями
- Розробляє французька Filigran за підтримки уряду Франції

Демо: відео на YouTube

III

Цикл розвідки

Від вимог до звіту і обміну інформацією — етап за етапом

ПРОЦЕС

Цикл розвідки: п’ять етапів

01

Планування та спрямування

Визначаємо вимоги до розвідки

02

Збір

Обираємо джерела й оцінюємо їхню надійність

03

Обробка

Перевіряємо індикатори й правдивість

04

Аналіз

Збагачуємо внутрішньою інформацією

05

Інформування

Адаптуємо під аудиторію і ділимось

> Це цикл, а не конвеєр: відгук споживачів після інформування стає новими вимогами для планування.

Вимоги роблять розвідку корисною

Вимоги визначають, щоб інформація про кіберзагрози була корисною та дієвою. Є два підходи.

GIR · ПОСТІЙНІ

Загальні вимоги розвідки

Узагальнені вимоги з моделі загроз, геополітичної ситуації чи інших джерел.

«Усі атаки з боку APT28, APT29, APT44»
«Усі атаки на фінансовий сектор України»

PIR · ОДНОРАЗОВІ

Пріоритетні вимоги розвідки

Конкретні запити під окреме питання.

«Знайди відомі набори вторгнень в'єтнамського походження, що діяли протягом останніх пів року»

Детальніше: Intel 471, Cybercrime Underground GIR

ЕТАП 2 · ЗБІР

Кожне джерело має оцінку надійності

Джерела бувають відкриті й закриті. Кожне оцінюємо за адміралтейською шкалою.

Джерело	Оцінка	Чому
CERT-UA	B — зазвичай надійне	Державна установа, неправдивих даних не подавала
Kaspersky	C — відносно надійне	Неправдивого не подавала, але компанія з країни-агресора може потрапити під урядовий тиск
Cyble	? — не оцінено	Оцінку ще треба сформувати

Зручний перелік джерел · Collection Management Framework



ЕТАП 3 · ОБРОБКА

Перевіряємо, перш ніж блокувати

Ми ж не хочемо раптом заблокувати легітимний і потрібний сервіс — публічний DNS-сервер чи домен комерційної хмари.

- Індикатори зручно перевіряти через AlienVault, але список однаково треба переглянути самому.
- Не все, що потрапило до рук, — правда: допомагає оцінка надійності джерела і підтвердження з незалежного джерела.
- Хороший тон — оцінювати за адміралтейською шкалою і саму інформацію.

ВАЖЛИВО

Жоден інструмент не вирішить за вас, чи є в списку хибні спрацювання.

Збагачуємо внутрішньою інформацією

Ключові питання:

- Чи траплялись у нас такі або схожі атаки?
- Чи є в нас пристрої, вразливі до таких атак?
- Що зробити, щоб уникнути таких атак?
- Чи є готові або легкодоступні рішення?
- Що найважливіше зробити першочергово?

ПОЛЮВАННЯ НА ЗАГРОЗИ

Якщо атака могла статися і в нас — проводимо полювання.

Правила YARA чи Sigma — через EDR, мережеві IOC — на мережевих пристроях. Готові правила є на майданчику SOC Prime, компанії з українським корінням.

АТРИБУЦІЯ

Один суб’єкт загроз — багато назв

- Кожна компанія бачить схожі TTP та інструменти у себе чи в клієнтів, але не може надійно зіставляти їх з даними інших — наприклад, через обмеження клієнтів на поширення.
- Ініціативи з уніфікації назв є: Microsoft і CrowdStrike зіставили свої назви. Але, ймовірно, нічим вони не завершаться.
- Просте рішення зараз — бази знань на кшталт Malpedia.

ПРИКЛАД

Gamaredon Group

він же:

ACTINIUM | Aqua Blizzard | UAC-0010

ЕТАП 5 · ІНФОРМУВАННЯ

Кожному – своє

IOC	**Системам захисту** У моніторинг і фаєрволи — з контекстом
TTP	**Командам реагування** Як розвиватиметься атака; правила виявлення
Звіти	**Керівництву** Чи захищені ми від актуальних атак

CTI Blueprints — шаблони звітів · APT1 — один з перших звітів CTI



ОБМІН · TRAFFIC LIGHT PROTOCOL

Хто може бачити звіт

Мітки обмежують поширення, щоб чутливе про інфраструктуру не витекло.

TLP:RED

Лише кінцевому одержувачу

TLP:AMBER

Лише в організації-одержувачі

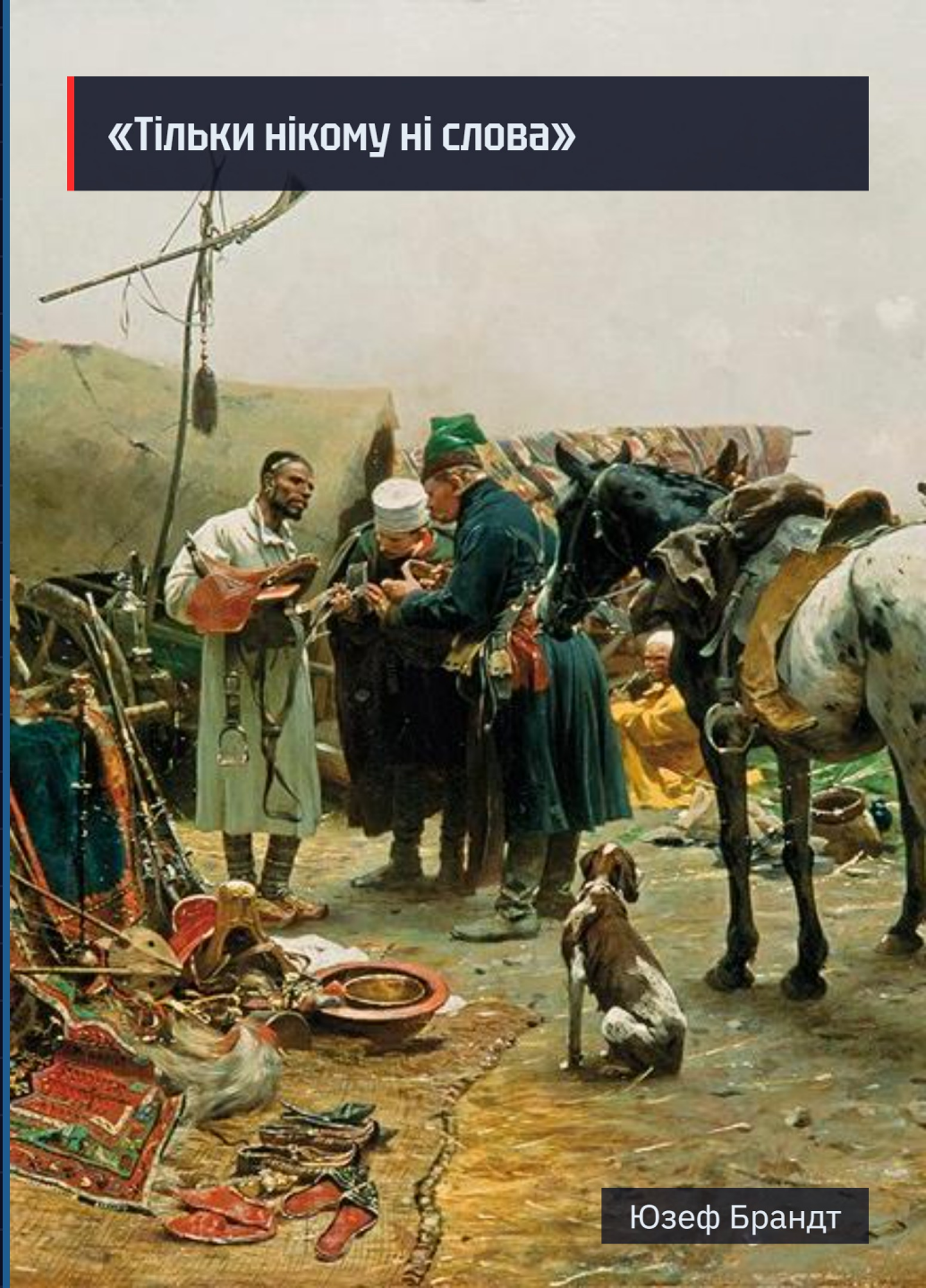
TLP:GREEN

У межах спільноти чи сектору

TLP:CLEAR

Без обмежень

Джерело: Держспецзв’язку, протокол TLP



ВИСНОВКИ

Підсумки

1

Розвідка – це контекст

Дисципліна, що надає контекст для прийняття рішень

2

Ринок ще формується

Передумови для росту попиту є, але бізнесу користь CTI поки неочевидна

3

Як розвиватись

Шукати менторів, працювати на міжнародні компанії або на клієнтів з Європи й США



Питання й обговорення

Іван Гокін LinkedIn · GitHub

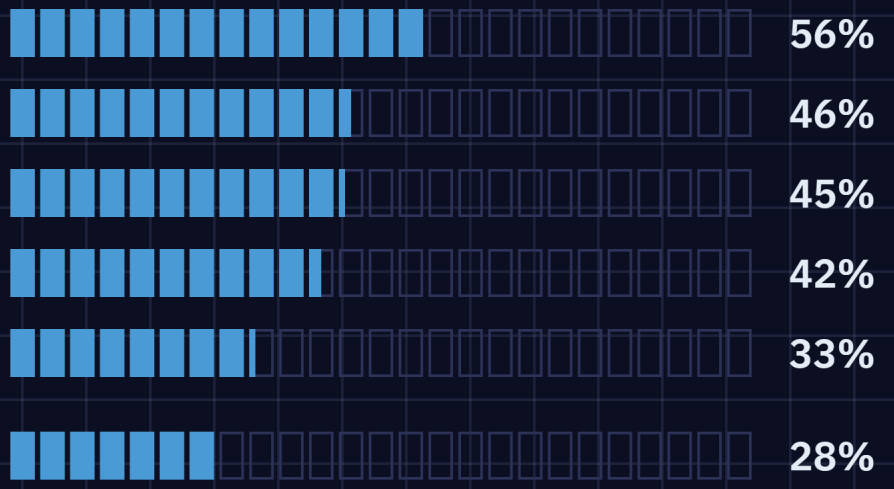
Дякую польському художнику Юзефу Брандту за ці прекрасні картини

ШІ: від експериментів до роботи

45%
CTI-команд уже використовують ШІ

32%
планують почати

ДЛЯ ЧОГО ВИКОРИСТОВУЮТЬ ШІ



ШІ не замінює аналітиків — він звільняє їм час. Остаточне рішення за людиною.

Джерело: SANS CTI Survey 2026

ДОДАТОК 2

Стандарти й рамки

NIST

SP 800-150

Guide to Cyber Threat Information Sharing

ЗРІЛІСТЬ

CTI-CMM

Cyber Threat Intelligence Capability Maturity Model

ЄС

CERT-EU

Cyber Threat Intelligence Framework

ДОДАТОК З

Кого варто почитати

Ресурс	Чим корисний
FIRST	Безкоштовні, практичні й корисні курси з розвідки кіберзагроз
Venation	Підкаже, як організувати процеси
Adam Goss	Багато практичних порад
Flare.io	Регулярні виступи на цікаві теми
Intel-ops.io: Hunting Adversary Infrastructure	Курс, що допоможе розмотати одну IP-адресу в цілісну історію

Перевірте свої навички

ПРАКТИКА

CTI Analyst Challenge

На випадок, коли хочеться розібратись і перевірити свої навички.

github.com/BushidoUK/CTI-Analyst-Challenge

Гарний приклад: огляди загроз від SEKOIA.IO

росія

Кібернаслідки російсько-української війни за рік

Іран

Огляд кіберзагроз з боку Ірану

КНДР

Як влаштовані кіберспроможності КНДР — не лише Lazarus

Китай

Екосистема китайських державних кіберзагроз